

W konfiguracji WAF w Cloudflare podchodzę do tematu tak samo, jak projektując zabezpieczenia w Azure: najpierw warstwa zarządzana, potem reguły niestandardowe, a na końcu precyzyjne wykluczenia, żeby nie generować false positives. W praktyce zaczynam od włączenia **Cloudflare Managed Rules** w trybie blokującym dla kategorii SQL Injection i XSS, bo działają podobnie jak **Azure WAF Managed Rules** i dają mi solidną bazę. Dopiero na tym fundamencie dokładam własne reguły, które dopasowuję do specyfiki aplikacji e-commerce. Dla SQLi stosuję inspekcję parametrów zapytań i ciała żądania pod kątem wzorców takich jak union select, sleep(), benchmark() czy information_schema, ale zamiast od razu blokować, zaczynam od „Managed Challenge”, żeby nie wycinać ruchu legalnych użytkowników. Podobnie przy XSS – reaguję na <script, javascript: czy onerror=, ale dopiero po analizie logów przełączam reguły na pełne blokowanie.

W przypadku ataków L7, które w Azure zwykle łagodziłabym za pomocą **Azure Front Door / WAF**, w Cloudflare wykorzystuję **Rate Limiting Rules** na najbardziej wrażliwych endpointach, takich jak /login, /checkout czy /api/*. Ustawiam limity per IP, ale z wyjątkami dla znanych integracji (np. bramki płatności), żeby nie blokować ruchu systemowego. Dodatkowo korzystam z **Super Bot Fight Mode** oraz **Bot Management Enterprise**, które działają podobnie do Azure Bot Protection, ale są znacznie skuteczniejsze w

analizie zachowań. W praktyce oznacza to, że ruch o niskim score botowym trafia na „Managed Challenge”, a tylko ewidentne boty są blokowane.